

a hacker could do is post a message to someone in the own contact list using an id.

The idea here is to expose as little as possible about the internal working of the system. If there are any obvious parameters that people are able to manipulate, don't expect them not to.

Let us look at a famous example of such an exploit in Hotmail, back in 2001. A user accessing their email account could see a URL such as:

<http://lw2fd.hotmail.msn.com/cgi-bin/getmsg?curmbox=F000000001&a=5691b2b44e104176111971aa0fbb1274&msg=MSG998000947.3&start=197078&len=1060&msgread=1&mfs=182>

Here the URL is exposing an internal data object, the message ID, which here is (MSG998000947.3). As it so happens, this message id is unique for each message. Using this message ID, one could access this message even when they are not logged into the account with which this email is associated.

So if the message (MSG998000947.3) existed for the user hackedguy@hotmail.com, some other Hotmail user haxOr@hotmail.com could access this message from their own account with a specially crafter URL. A hacker would just need to insert the right values into the right locations in the attach URL in order to see the message:

http://pv2fd.pav2.hotmail.msn.com/cgi-bin/saferd?_lang=EN&hm__tg=http%3a%2f%2f64%2e4%2e36%2e250%2fcgi%2dbin%2fgetmsg&hm__qs=%26msg%3dMSGXXXXXXXXX%2eX%26start%3d1%26len%3d9999999999%26login%3dUSERNAME%26domain%3dhotmail%2ecom

Note: The unescaped URL is: http://pv2fd.pav2.hotmail.msn.com/cgi-bin/saferd?_lang=EN&hm__tg=http://64.4.36.250/cgi-bin/getmsg&hm__qs=&msg=MSGXXXXXXXXX.X&start=1&len=9999999999&login=USERNAME&domain=hottmail.com

Here the attacker would enter the message number (MSG998000947) in the bolded location marked MSGXXXXXXXXXX, and the value after the period (3) in the original URL in the X following that. In the place marked USERNAME, the attacker would place the username of the user to whom the message belongs. Finally, we would have a URL as follows:

http://pv2fd.pav2.hotmail.msn.com/cgi-bin/saferd?_lang=EN&hm__tg=http%3a%2f%2f64%2e4%2e36%2e250%2fcgi%2dbin%2fgetmsg&hm__qs=%26msg%MSG998000947%2e3%26start%3d1%26len%3d9999999999%26login%3dhackedguy%26domain%3dhotmail%2ecom

On visiting this URL in the browser while being logged into any other Hotmail account, an attacker could view messages belonging to another user. People could brute force the message codes by trying different values until one worked and get access to other people's emails. Hacking utilities for finding valid message codes also started becoming available.